



מערכת TALA – ארכיטקטורת מערכת ואבטחת מידע

סקירה טכנולוגית מקיפה: תשתית ענן מאובטחת (GitHub SSL/TLS & Firebase), הצפנת סיסמאות, בקרת הרשאות, הגנת פרטיות (PII) ופיתוח קוד מאובטח (Secured Code Attitude)



Secured Code Attitude

קוד מודולרי מבוסס Domain, סניטציית קלטים, אחסון מוגן שגיאות, הפקת מסמכים מקומית בדפדפן, ובדיקות אוטומטיות ב-CI.



הגנת פרטיות הקטין (PII)

המרה אוטומטית לראשי תיבות (ג.י.) בכל הטקסטים והשחרת ת.ז/טלפון/כתובת () בהדפסה, ב-Word, ב-PDF ובמייל.



בקרת גישה ובידוד נתונים

אימות דו-שכבתי ב-Firebase Auth ובחוקי שרת (firestore.rules), בידוד תיקי תלמידים לפי ownerEmail ושיתוף צוותי מבוקר.



הצפנת סיסמאות ואימות

רשימת מורשים סגורה (Allowlist), גיבוב חד-כיווני 256 (SHA-256), מדיניות rounds + 128-bit Salt, סיסמה קשיחה וחסימת Brute-Force.



GitHub SSL/TLS & CDN

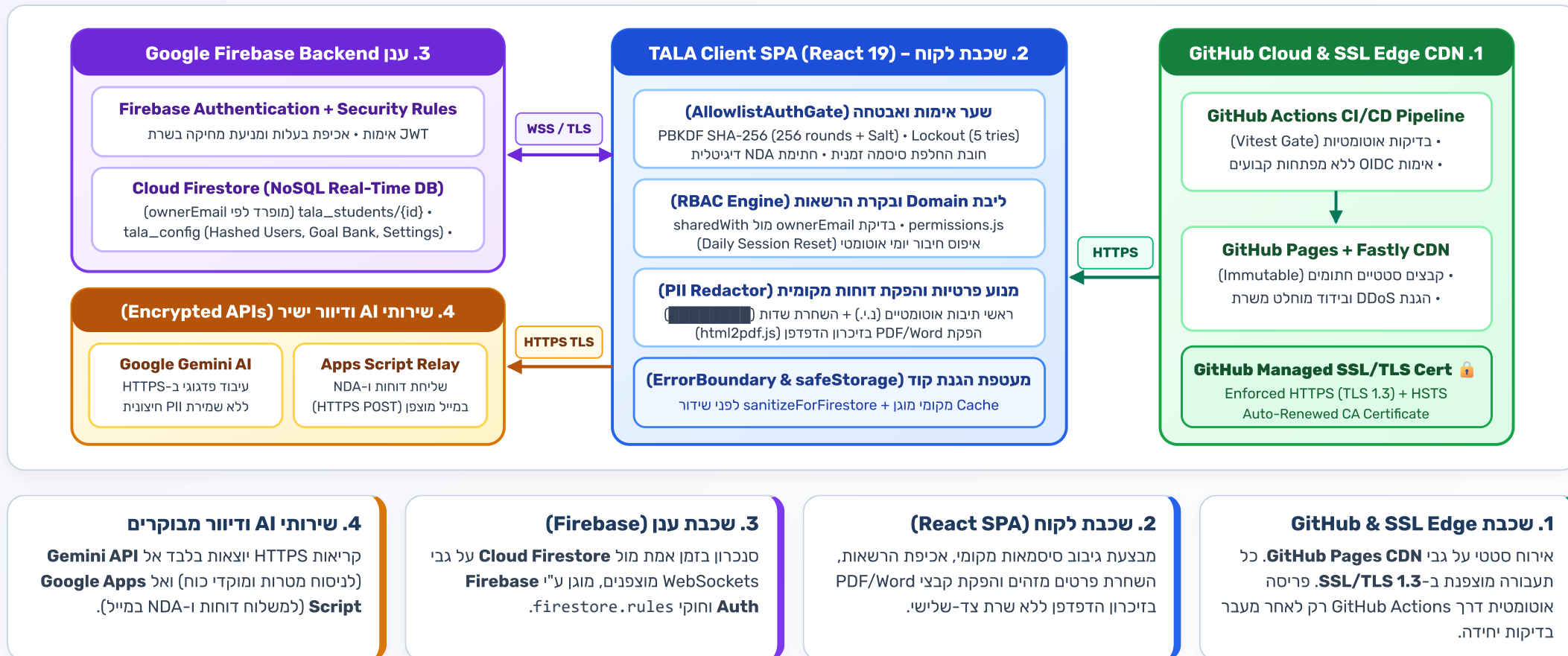
תעודת SSL/TLS אוטומטית (HTTPS בלבד), רשת הפצה גלובלית מוגנת DDoS, ופריסת CI/CD מאובטחת ב-OIDC עם הרשאות מינימליות.



1. ארכיטקטורת המערכת מקצה לקצה (High-Level System Architecture Diagram)

ארכיטקטורת Serverless SPA מודרנית המפרידה בין שכבת התצוגה הסטטית, שכבת הענן המאובטחת ושירותי ה-AI והדיוור

System Architecture Diagram

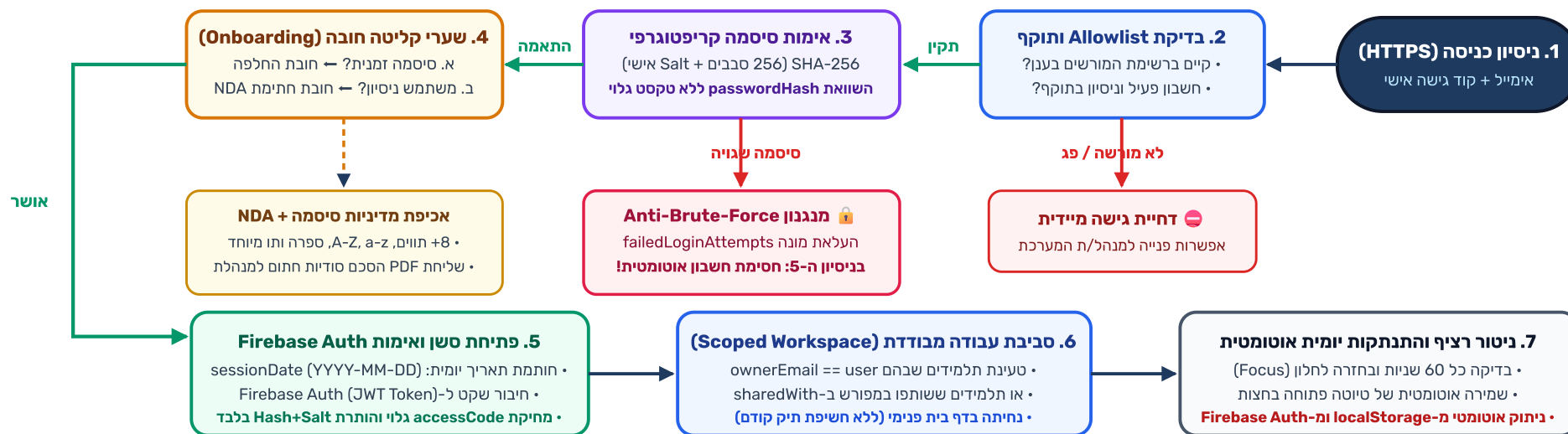




2. תרשים זרימה אבטחתי: אימות, הצפנה, NDA וניהול סשן (Security Flowchart)

תהליך בקרת הכניסה הרב-שלבי החל מהזנת פרטי המשתמש ועד לסגירת הענן והתנתקות יומית אוטומטית

Authentication & Session Flowchart



הגנה על מחשבים משותפים בגן ובבית הספר

מנגנון `isSessionUserValidForToday` מוודא כי חיבור שנשאר פתוח במחשב הגן או חדר המורים מתנתק אוטומטית עם התחלפות יום הלוח (תוך שמירת טיוטות לא שמורות).

חתימה דיגיטלית על NDA למשתמשי ניסיון

משתמש ניסיון (`isTrialUser`) מחויב לחתום על גבי משטח חתימה דיגיטלי. החתימה מוטמעת כקובץ PDF רשמי וכטבלת פיקסלים חסינת חסימות ונשלחת אוטומטית למנהל המערכת.

גיבוב קריפטוגרפי רב-סבבי (PBKDF)

במקום לשמור סיסמאות גליות, הפונקציה `hashPasswordWithSalt` מייצרת Salt 128-bit אקראי לכל משתמש ומבצעת **256 סבבי SHA-256** עם הפרדת דומיין (`TALA_PBKDF_V1`).

firestore.rules

אכיפת הרשאות בענן
(Firestore Rules)

בסיס הנתונים בענן של Google מוגן בשתי שכבות: הצפנת AES-256 במנוחה (Encryption at Rest) וחוקי גישה ברשת:

- אימות זהות ברשת: בעת הכניסה, `ensureFirebaseAuthSession` רשם/מחבר את המורה ל-Firebase Auth כך שהשרת מקבל טוקן חתום (`request.auth.token.email`).
- בידוד בעלות (`isOwnerOfResource`): גישה לקריאה ועריכה של כרטיס תלמיד ב-`tala_students/{id}` מותרת רק לבעל הכרטיס (`ownerEmail`), לשותפי צוות ב-`sharedWith` או למנהלת המערכת.
- הגנה מפני חטיפת בעלות ומחיקה: חוקי השרת אוסרים על שותפים (`sharedWith`) לשנות את שדה `ownerEmail`, לארכב תלמיד או למחוק אותו (`allow delete: if isOwnerOfResource`).

deploy.yml

אבטחת תהליך הבנייה
(GitHub Actions)

תהליך הפריסה מוגדר בקובץ `.github/workflows/deploy.yml` ופועל לפי עקרונות Zero-Trust CI/CD:

- הרשאות מינימליות (`Least Privilege Token`): ה-Workflow מצהיר במפורש על `contents: read`, `pages: write` ו-`id-token: write` בלבד – ללא יכולת שינוי קוד המקור.
- אימות OIDC ללא סודות קבועים: הפריסה מתבצעת באמצעות טוקן זמני (OpenID Connect) מול סביבת `github-pages` מוגנת, ללא שמירת מפתחות SSH או טוקנים ארוכי-טווח.
- שער איכות ובדיקות אוטומטי (`Quality Gate`): הפקודה `npm run test:run` מריצה את מערך הבדיקות (Vitest) לפני בניית האתר; כישלון בבדיקת אבטחה או הרשאות עוצר את הפריסה מיידית.

TLS 1.3

תעודת SSL/TLS רשמית של
GitHub

האפליקציה מתארכת על תשתית **GitHub Pages** המוגנת באמצעות רשת ה-CDN העולמית של Fastly ותעודת SSL מנוהלת:

- תעודת **SSL X.509** מנוהלת ומתחדשת אוטומטית: מונפקת ע"י רשות אישורים מוסמכת (Let's Encrypt / DigiCert) ומותקנת אוטומטית על הדומיין `zivitreshef.github.io`.
- כפיית **HTTPS מוחלטת (Enforce HTTPS)**: כל פנייה ב-HTTP מופנית אוטומטית (301 Redirect) לערוץ מוצפן ב-**TLS 1.2 / TLS 1.3**, כולל כותרות **HSTS** למניעת מתקפות MITM ו-SSL Stripping.
- אפס משטח תקיפה צד-שרת: מכיוון שהאתר מוגש כנכסים סטטיים חתומים בלבד (Immutable Static Bundle), לא קיים שרת אפליקטיבי החשוף ל-SQL Injection או הרצת קוד מרחוק (RCE).

100% HTTPS / TLS Enforced

הצפנה מקצה לקצה בכל ערוצי התקשורת (**End-to-End Encrypted Channels**): בין דפדפן המורה ל-GitHub Pages (**HTTPS TLS 1.3**) • בין הדפדפן ל-Cloud Firestore (**Encrypted gRPC/WebSockets over TLS**) • בין הדפדפן ל-Gemini AI ול-Google Apps Script (**HTTPS TLS**).



4. גישת פיתוח קוד מאובטח והנדסת פרטיות (Secured Code Attitude)

עקרונות כתיבת קוד הגנתי (Defensive Programming), הפרדת אחריות, הגנה מפני דליפת מידע והשחרת PII אוטומטית

Secured Code Attitude & Privacy by Design

2. הנדסת פרטיות והשחרת פרטים מזהים (PII Redaction)

src/domain/privacyAndAcronyms.js

- ברירת מחדל מחמירה (Secure by Default): הדגל `hideDetailsInPrint = true` מופעל אוטומטית בכל שלושת הדוחות (תל"א/תח"י, דוח הערכה, ודו"ח מצב חינוכי-תפקודי).
- סריקה והחלפה חכמה בתוך טקסט חופשי: הפונקציה `redactStudentNameInText` מזהה את שמו המלא ושמו הפרטי של התלמיד בתוך תיאור התפקוד, המטרות ודו"ח המצב ומחליפה אותם אוטומטית בראשי תיבות (`toHebrewAcronym`), למשל: "נועם ישראלי" → "נ.י."
- השחרת שדות רגישים והפקה מקומית: הפונקציה `maskSensitiveValue` משחירה ת.ז., תאריך לידה, טלפון, כתובת ומסגרת (██████████). קבצי ה-PDF וה-Word נוצרים בזיכרון והדפדפן בלבד ללא העלאה לשרת המרה חיצוני.

1. היגיינת סיסמאות והסרת טקסט גלוי אוטומטית

src/allowedUsers.js

- מימוש קריפטוגרפי עצמאי ללא תלות בספריות חיצוניות פגיעות: מימוש תקן FIPS 180-4 SHA-256 טהור (`sha256Hex`) כדי למנוע מתקפות שרשרת אספקה (Supply-Chain Attacks) מחבילות צד-שלישי.
- הגירה ושדרוג אוטומטי (Self-Healing Credential Migration): הפונקציה `ensureUsersListPasswordsHashed` סורקת כל רשימת משתמשים (מקומית או מהענן), ממירה כל קוד גישה ל-`{ passwordSalt, passwordHash }` ומוחקת פיזית את המאפיין `accessCode` מהאובייקט לפני השמירה.
- הגנה על מפתחות API מפני סורקים: קבצי `.env.local` מוחרגים ב-`.gitignore`, ומפתחות ברירת מחדל מורכבים בזמן ריצה ממערך בתים (`String.fromCharCode`) למניעת חשיפה בסריקות טקסט סטטיות.

4. אכיפת הרשאות ב-Domain, בקרת AI ובדיקות אוטומטיות

src/domain/permissions.js

- הפרדת הרשאות קשיחה בקוד (Single Source of Truth): פונקציות הבקרה `canViewStudent`, `canDeleteStudent`, `canArchiveStudent` ו-`canLockReport` מוודאות שרק היוצר המקורי (`ownerEmail`) רשאי לנעול, לארכב, לשתף או למחוק.
- מניעת הזיות AI ודריסת עריכות (Hallucination & Overwrite Guards): דו"ח המצב מופק אך ורק מנתונים קיימים בכרטיס (סעיפים ריקים מושמטים), ומטרות שהמורה ערכה ידנית מסומנות ומוגנות מפני דריסה בעיבוד AI חוזר.
- כיסוי בדיקות אוטומטי (coreDomain.test.js): בדיקות יחידה מוודאות אוטומטית את תקינות הגיבוב, ההרשאות, השחרת ה-PII וגלגול השנים בכל שינוי קוד.

3. תכנות הגנתי, סניטציה ועמידות בפני כשלים

src/services/storage.js

- עטיפות אחסון מוגנות (Safe Storage Wrappers): קריאות וכתיבות ל-`localStorage` עוברות דרך `safeGetStorageJson` ו-`safeSetStorageJson` המגנות מפני גלישה בסתר או הזרקת JSON פגום. `QuotaExceededError`.
- סניטציה לפני כתיבה לענן: הפונקציה `sanitizeForFirestore` מנקה ערכי `undefined` ומבנים לא תקינים לפני כל שמירה ב-Firestore.
- מניעת דליפת מידע בשגיאות (ErrorBoundary): הרכיב `src/components/ErrorBoundary.jsx` לוכד שגיאות ריצה ומציג מסך שחזור מבוקר בעברית מבלי לחשוף פרטי קוד או נתוני תלמיד על המסך.



5. מטריצת אבטחה רב-שכבתית וסיכום בקורות (Defense-in-Depth Security Matrix)

מיפוי מלא של איומי אבטחה ופרטיות אל מול מענה הארכיטקטורה והקוד במערכת TALA

Security Controls Matrix

שכבה בארכיטקטורה	איום / סיכון אבטחתי (Threat Vector)	בקרת האבטחה במערכת (TALA Security Control & Mitigation)	מימוש בקוד / תשתית (Code Reference)
1. רשת ואירוח Network & Hosting	האזנת סתר ברשת (MITM), זיוף אתר או תקיפת שרת	תעודת GitHub SSL/TLS רשמית ומתחדשת אוטומטית, כפיית HTTPS (TLS) + HSTS (1.3) , הפצה דרך Fastly CDN כקבצים סטטיים בלבד ללא שרת חשוף.	<code>GitHub Pages SSL</code> <code>.github/workflows/deploy.yml</code>
2. אימות וסימאות Authentication	חשיפת סיסמאות במאגר או מתקפת ניחוש (Brute-Force)	גיבוב חד-כיווני SHA-256 (256 סבבים) + bit Random Salt-128 אישי; מחיקת סיסמה גלויה; חסימת חשבון אוטומטית לאחר 5 ניסיונות כושלים; חובת החלפת סיסמה זמנית.	<code>allowedUsers.js</code> <code>hashPasswordWithSalt()</code>
3. ניהול ששן ומחשבים משותפים Session Security	מחשב שהושאר פתוח בגן / בכיתה או פקיעת תקופת ניסיון	חותמת תאריך יומית (YYYY-MM-DD) ובדיקה רציפה כל 60 שניות: התנתקות אוטומטית בחצות (תוך שמירת טיוטה פתוחה), וחסימה אוטומטית בתום ימי הניסיון.	<code>App.jsx</code> <code>isSessionUserValidForToday()</code>
4. הרשאות וענן Cloud & RBAC	צפייה בתיקי תלמידים של מורה אחרת או מחיקה ע"י שותף	אימות מול Firebase Auth ואכיפת חוקים בשרת ובקוד: בידוד מלא לפי <code>ownerEmail</code> ; שותפים ב- <code>sharedWith</code> מנועים מלמחוק, לארכב, לנעול או לשנות בעלות.	<code>firestore.rules</code> <code>domain/permissions.js</code>
5. פרטיות הקטין Student PII Privacy	חשיפת שם תלמיד, ת.ז או כתובת בהדפסה או בשליחה במייל	מצב " הסתר פרטים מזהים " מופעל כברירת מחדל : המרת שם התלמיד לראשי תיבות (ג.י.) בכותרת ובכל הטקסטים החופשיים, והשחרת ת.ז/טלפון/כתובת ().	<code>privacyAndAcronyms.js</code> <code>redactStudentNameInText()</code>
6. קניין רוחני ואיכות קוד IP & Code Integrity	הפצה לא מורשית בגרסת ניסיון או באגים/קריסות בדפדפן	שער חתימה דיגיטלית על NDA למשתמשי ניסיון עם משלוח PDF חתום למנהלת; סניטציית נתונים (<code>sanitizeForFirestore</code>); <code>ErrorBoundary</code> ; ובדיקות יחידה ב-CI.	<code>TrialNdaModal.jsx</code> <code>coreDomain.test.js</code>

סיכום אבטחתי (Executive Security Summary):

TALA • Security & Architecture Verified

מערכת TALA משלבת תשתית ענן תקנית ומוצפנת (**GitHub Pages SSL/TLS + Google Cloud Firestore**) עם ארכיטקטורת קוד מוקפדת (**Secured Code Attitude**) המעניקה לצוותי החינוך והמתי"א סביבת עבודה בטוחה, ממודרת ושומרת פרטיות מקצה לקצה.